

RAPPORT TECHNIQUE

Évaluation des risques cloud et audit GRC sur Azure

Audit de configuration, cartographie des risques et plan de traitement
aligné NIST CSF / CIS Controls / ISO 27001 / ANSSI

Préparé par : Koman Ohouo Joseph

Étudiant ingénieur – Réseaux et Sécurité

1. Résumé exécutif

Ce rapport présente les résultats d'une évaluation des risques menée sur un environnement de laboratoire Microsoft Azure. Le périmètre principal est constitué du compte de stockage **grstoragelab**, rattaché au groupe de ressources **GRC-Lab** et hébergé dans la région *France Central*. L'objectif de la mission est d'identifier les erreurs de configuration, d'en mesurer les conséquences potentielles et de proposer un plan de traitement exploitable dans une démarche de gouvernance, risque et conformité.

L'évaluation met en évidence plusieurs risques de niveau élevé à critique. Les constats les plus importants sont l'autorisation de l'accès anonyme aux objets Blob, la configuration publique du conteneur **donnees-sensibles**, l'ouverture du service à l'ensemble des réseaux, l'utilisation de deux clés d'accès à portée étendue sans rotation automatique démontrée et la désactivation des paramètres de diagnostic. Pris ensemble, ces éléments pourraient permettre l'accès non autorisé à des données, l'utilisation abusive d'identifiants partagés et une détection tardive d'un incident.

Le niveau de risque global de l'environnement est évalué comme **critique**. Les priorités sont de rendre immédiatement le conteneur privé, de désactiver l'accès anonyme, de limiter l'accès réseau, de remplacer progressivement les clés partagées par Microsoft Entra ID et le RBAC, puis d'activer la journalisation et les alertes. Aucune exploitation malveillante n'a été observée dans le cadre de ce laboratoire et aucune donnée sensible réelle n'a été utilisée.

2. Périmètre et environnement

L'audit porte uniquement sur les ressources et paramètres visibles dans les captures fournies. Il ne constitue pas une certification de conformité de l'ensemble du tenant Azure.

Élément	Configuration observée
Groupe de ressources	GRC-Lab
Compte de stockage	grstoragelab
Région	France Central
Type de compte	StorageV2 – compte v2 à usage général
Performance	Standard
Réplication	Stockage localement redondant (LRS)
Conteneur Blob	donnees-sensibles
Accès au conteneur	Créé initialement en mode privé, puis rendu accessible anonymement pour la simulation
Accès réseau	Réseau public activé depuis tous les réseaux
Clés d'accès	Deux clés de compte disponibles
Journalisation	Paramètres de diagnostic classiques désactivés

Le périmètre inclut l'accès public aux blobs, le niveau d'accès du conteneur, les clés d'accès, les restrictions réseau et la journalisation. Les politiques Microsoft Entra ID, le MFA, les applications consommatrices, les sauvegardes, les règles Azure Policy et les autres ressources du tenant sont hors périmètre faute d'éléments de preuve suffisants.

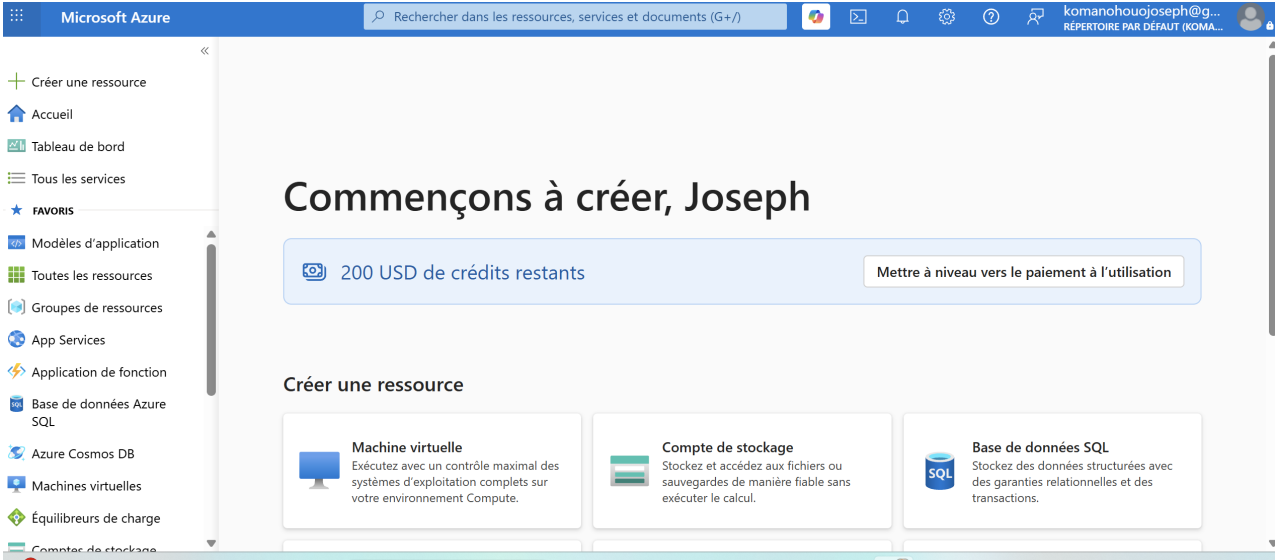


Figure 1 – Page d’accueil du portail Microsoft Azure utilisée pour le laboratoire.

3. Synthèse : Actifs, Menaces, Vulnérabilités

3.1 Actifs identifiés

Actif	Catégorie	Pourquoi c’est important
Compte de stockage Azure	Infrastructure	Héberge les services de stockage et centralise une partie des paramètres de sécurité.
Conteneur donnees-sensibles	Données	Peut contenir des documents métier, des données clients ou des informations financières.
Clés d’accès key1 et key2	Identité / Accès	Donnent un accès étendu au compte de stockage et doivent être protégées comme des secrets critiques.
Configuration réseau	Réseau	Détermine les origines autorisées à atteindre le service depuis Internet ou un réseau privé.
Journaux de diagnostic	Supervision	Permettent de détecter, comprendre et investiguer les activités suspectes.

3.2 Menaces identifiées

Actif concerné	Scénario de menace
Conteneur Blob	Consultation, téléchargement ou énumération de données par un utilisateur anonyme.
Clés d’accès	Vol, fuite ou réutilisation d’une clé donnant un accès étendu au stockage.
Configuration réseau	Tentatives d’accès depuis une adresse IP ou un réseau non autorisé.
Compte Azure / IAM	Abus de privilèges ou modification non autorisée de la configuration.
Journaux	Activité malveillante non détectée ou investigation impossible faute de traces suffisantes.

3.3 Vulnérabilités identifiées

Vulnérabilité	Explication
Accès anonyme aux objets Blob activé	Le compte autorise l'accès anonyme aux objets Blob. Cette option permet à un conteneur d'être rendu public et augmente le risque d'exposition de données.
Conteneur public	Les captures montrent un passage du niveau <i>Blob</i> au niveau <i>Conteneur</i> . Le niveau <i>Conteneur</i> , plus permissif, autorise la lecture et l'énumération anonymes des objets.
Accès réseau non restreint	Le réseau public est activé depuis tous les réseaux, sans restriction visible par adresse IP, réseau virtuel ou point de terminaison privé.
Clés partagées à forte portée	Deux clés de compte sont disponibles et l'accès par clé est autorisé. Une clé divulguée pourrait être utilisée sans bénéficier de la granularité du RBAC.
Rotation non imposée	Un rappel manuel de 60 jours a été testé, mais ce mécanisme ne réalise pas la rotation. Une autre capture montre le rappel désactivé : aucune rotation automatique obligatoire n'est donc démontrée.
Journalisation désactivée	Les paramètres de diagnostic classiques sont désactivés et aucune règle moderne de collecte n'est visible dans les preuves fournies.
Préférence Entra non activée	L'autorisation Microsoft Entra par défaut dans le portail est désactivée, ce qui favorise l'usage des clés partagées plutôt que des accès nominatifs et traçables.

Limite importante : l'état du MFA n'est pas visible dans les captures. L'absence de MFA n'est donc pas retenue comme constat avéré ; sa vérification fait néanmoins partie des recommandations.

4. Registre des risques

4.1 Méthode de quantification

Chaque risque est évalué selon deux axes notés de 1 à 5 : la probabilité d'occurrence et l'impact potentiel. Le score de criticité correspond au produit :

$$\text{Score de risque} = \text{Probabilité} \times \text{Impact}$$

Score	Signification – probabilité	Score	Signification – impact
1	Rare	1	Impact minimal
2	Peu probable	2	Impact mineur
3	Possible	3	Impact modéré
4	Probable	4	Impact élevé
5	Quasi certaine	5	Impact critique

Les scores supérieurs ou égaux à 15 sont considérés comme **critiques**. Les scores compris entre 9 et 14 sont **élevés**. Les scores de 4 à 8 sont **modérés** et les scores de 1 à 3 sont **faibles**.

4.2 Registre des risques

Actif	Menace	Prob.	Impact	Score	Justification
Conteneur Blob	Accès public non autorisé	4	5	20	Le niveau public peut permettre la lecture et l'énumération anonymes d'objets potentiellement sensibles.
Configuration réseau	Accès depuis une origine non approuvée	4	4	16	Le service est exposé à tous les réseaux publics, ce qui augmente la surface d'attaque.
Clés d'accès	Vol ou fuite d'une clé	3	5	15	Une clé compromise peut fournir un accès étendu au compte de stockage.
Journaux	Attaque non détectée	3	4	12	L'absence de collecte démontrée réduit les capacités de détection, d'alerte et d'investigation.
Compte Azure / IAM	Abus de privilèges	2	5	10	L'usage de clés partagées et l'absence de préférence Entra réduisent la granularité et la traçabilité des accès.

L'exposition publique du conteneur, l'ouverture réseau et le risque de compromission des clés constituent les trois priorités. La désactivation de la journalisation aggrave ces risques, car un accès non autorisé pourrait être détecté tardivement ou ne pas être suffisamment documenté.

5. Contrôles et mapping frameworks

Le plan de traitement s'appuie sur quatre référentiels complémentaires : NIST CSF, CIS Controls, ISO 27001 et les recommandations de l'ANSSI.

Référentiel	Description	Utilisation
NIST CSF	Cadre structuré et orienté gestion des risques cyber.	Gouvernance, protection, détection et réponse.
CIS Controls	Ensemble de mesures pratiques visant les attaques les plus courantes.	Priorisation de contrôles techniques opérationnels.
ISO 27001	Norme de référence pour le management de la sécurité de l'information.	Gouvernance, conformité et amélioration continue.
ANSSI	Recommandations françaises de référence en cybersécurité.	Hygiène, administration, cloisonnement et journalisation.

5.1 Typologie des contrôles

Type	Définition	Exemple
Préventif	Empêche ou limite l'attaque avant sa réalisation.	Désactiver l'accès public au Blob.
Détectif	Identifie et signale une activité suspecte.	Activer les journaux et les alertes.
Correctif	Réduit les conséquences d'un incident ou rétablit un état sûr.	Régénérer une clé compromise.

5.2 Mapping des contrôles

Risque	Contrôle	Type	NIST / CIS	ISO 27001	ANSSI
Accès public Blob	Désactiver l'accès anonyme et rendre le conteneur privé.	Préventif	CIS 3	A.8.2.3	R1

Risque	Contrôle	Type	NIST / CIS	ISO 27001	ANSSI
Vol de clés	Régénérer les clés, sécuriser les secrets et imposer le MFA aux comptes privilégiés.	Préventif / correctif	NIST PR.AC	A.9.4.2	R28
Accès réseau ouvert	Restreindre par pare-feu, réseaux sélectionnés ou Private Endpoint.	Préventif	CIS 12	A.13.1.1	R26
Absence de détection	Activer les diagnostics, centraliser les logs et créer des alertes.	Détectif	NIST DE.CM	A.12.4.1	R71
Abus de privilèges	Utiliser Microsoft Entra ID et appliquer le RBAC selon le moindre privilège.	Préventif	CIS 5	A.9.2.3	R18

6. Actions de remédiation recommandées

Les mesures suivantes sont classées par ordre de priorité :

1. **Supprimer immédiatement l'exposition anonyme.** Repasser le conteneur `donnees-sensibles` en mode *Privé*, puis désactiver l'option *Autoriser l'accès anonyme aux objets blob* au niveau du compte. Valider la correction par un test d'accès anonyme refusé.
2. **Restreindre l'accès réseau.** Remplacer l'accès depuis tous les réseaux par des réseaux sélectionnés. Pour un environnement sensible, privilégier un Private Endpoint et désactiver l'accès public lorsque cela est possible.
3. **Durcir l'authentification et la gestion des secrets.** Régénérer les deux clés après inventaire des dépendances, stocker les secrets dans Azure Key Vault et migrer les usages vers Microsoft Entra ID, les identités managées et le RBAC. Vérifier et imposer le MFA sur tous les comptes à privilèges.
4. **Activer la supervision.** Configurer les paramètres de diagnostic modernes, envoyer les journaux vers Log Analytics ou un SIEM, définir une durée de conservation adaptée et créer des alertes sur les changements d'accès public, les régénérations de clés et les opérations anormales.
5. **Mettre en place des garde-fous de gouvernance.** Déployer Azure Policy pour interdire les conteneurs publics, signaler les comptes ouverts à tous les réseaux et imposer la journalisation. Organiser une revue périodique des accès, des clés, des SAS et des exceptions.

7. Posture de risque globale

L'environnement présente une posture initiale **critique**. Cette évaluation résulte de la combinaison de trois faiblesses majeures : possibilité d'accès anonyme aux blobs, exposition réseau à Internet sans restriction et présence de clés partagées à forte portée. La désactivation de la journalisation augmente encore le risque, puisqu'elle limite la détection et l'investigation d'un accès non autorisé.

Dans un environnement réel contenant des données personnelles, financières ou stratégiques, cette configuration ne serait pas compatible avec les principes de moindre privilège, de défense en profondeur et de traçabilité. Le traitement doit donc commencer avant tout dépôt de données sensibles.

Après mise en œuvre des recommandations prioritaires, le niveau de risque résiduel pourrait être ramené à un niveau **modéré et maîtrisé**, sous réserve de vérifier les contrôles par des tests techniques : refus d'accès anonyme, blocage depuis un réseau non autorisé, validation des rôles RBAC, consultation effective des journaux et déclenchement d'une alerte de test.

La prochaine étape consiste à corriger les paramètres, conserver les preuves de remédiation, puis réévaluer les scores du registre des risques. Cette nouvelle évaluation permettra de confirmer le niveau de risque résiduel et de formaliser l'acceptation des éventuelles exceptions restantes.

Annexes – Captures d’écran Azure

Les captures ci-dessous constituent les éléments de preuve utilisés pour l’évaluation. Elles sont volontairement regroupées en fin de rapport. Avant toute publication publique, il est recommandé de masquer l’adresse du compte, l’identifiant d’abonnement et toute autre donnée d’identification visible.

Annexe A.1 – Portail Microsoft Azure

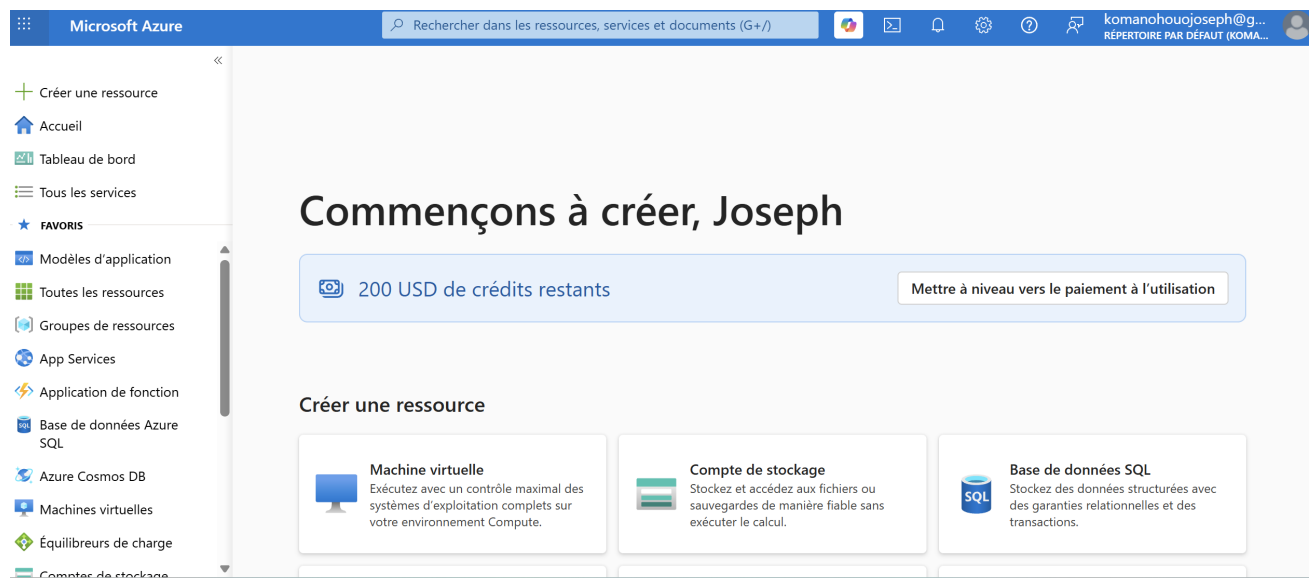


Figure 2 – Page d’accueil du portail Microsoft Azure utilisée pour le laboratoire.

Annexe A.2 – Création du compte de stockage

Microsoft Azure

Rechercher dans les ressources, services et documents (G+/)

Accueil > Gestionnaire des ressources | Groupes de ressources > GRC-Lab > Marketplace > Storage account

Créer un compte de stockage

Groupe de ressources *

gnc-lab
[Créer nouveau](#)

Détails de l'instance

Nom du compte de stockage * ①

grcstoragelab

Région * ①

(Europe) France Central
[Déployer sur une zone étendue Azure](#)

Service principal *

Choisissez le type de stockage préféré

① Elle nous permet d'offrir des conseils pertinents. Elle ne limite pas votre stockage à ce type de ressource. [Découvrir plus d'informations](#)

Performance * ①

☒ **Standard:** Recommandé pour la plupart des scénarios (compte universel v2)

☐ **Premium:** Recommandé pour les scénarios nécessitant une faible latence.

Précédent Suivant Vérifier + créer

[Envoyer vos commentaires](#)

Figure 3 – Création du compte *grcstoragelab* dans le groupe de ressources *GRC-Lab*, en région *France Central* et avec une performance *Standard*.

Annexe A.3 – Création du conteneur

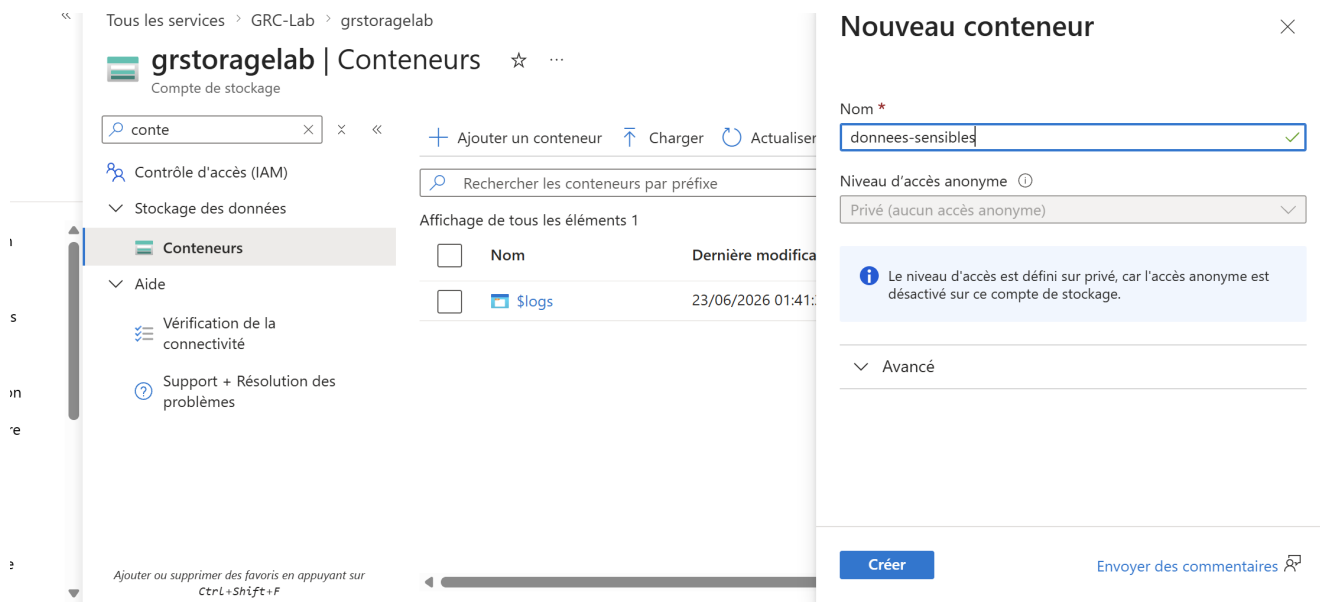


Figure 4 – Création du conteneur *donnees-sensibles* avec un niveau d'accès initial privé.

Annexe A.4 – Autorisation de l'accès anonyme

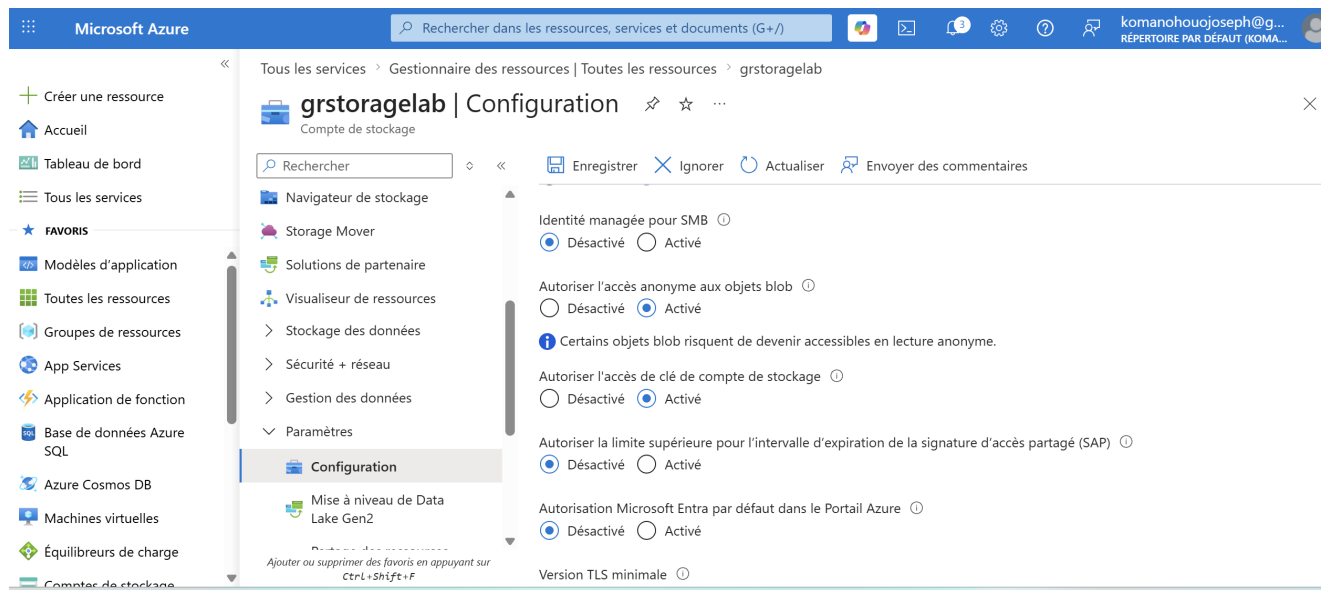


Figure 5 – Activation de l'accès anonyme aux objets Blob au niveau du compte de stockage.

Annexe A.5 – Niveau d'accès Blob

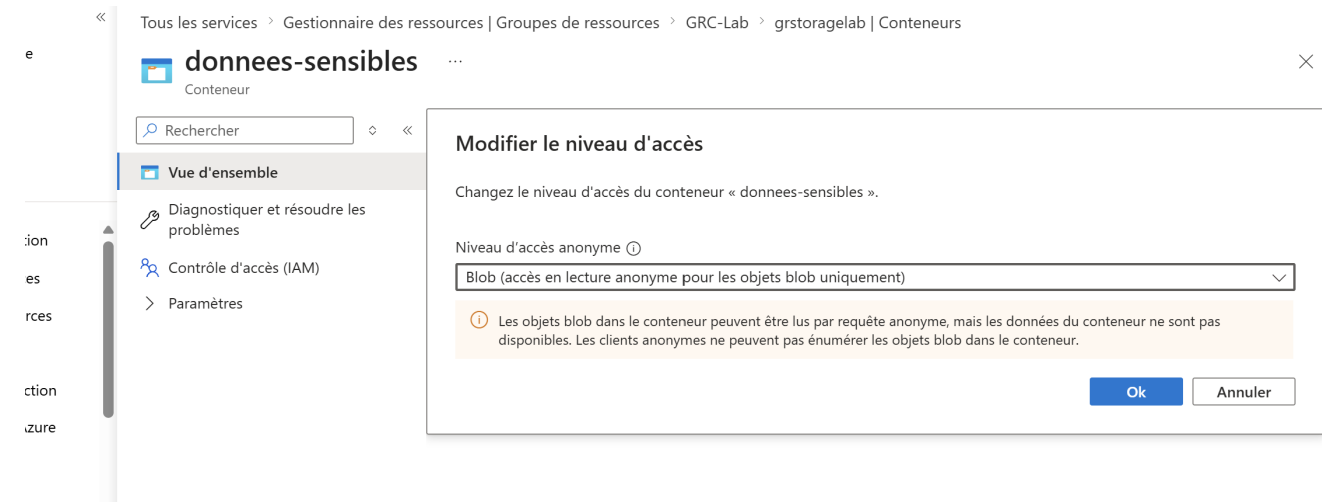


Figure 6 – Configuration du conteneur avec un accès anonyme limité aux objets Blob.

Annexe A.6 – Niveau d'accès Conteneur

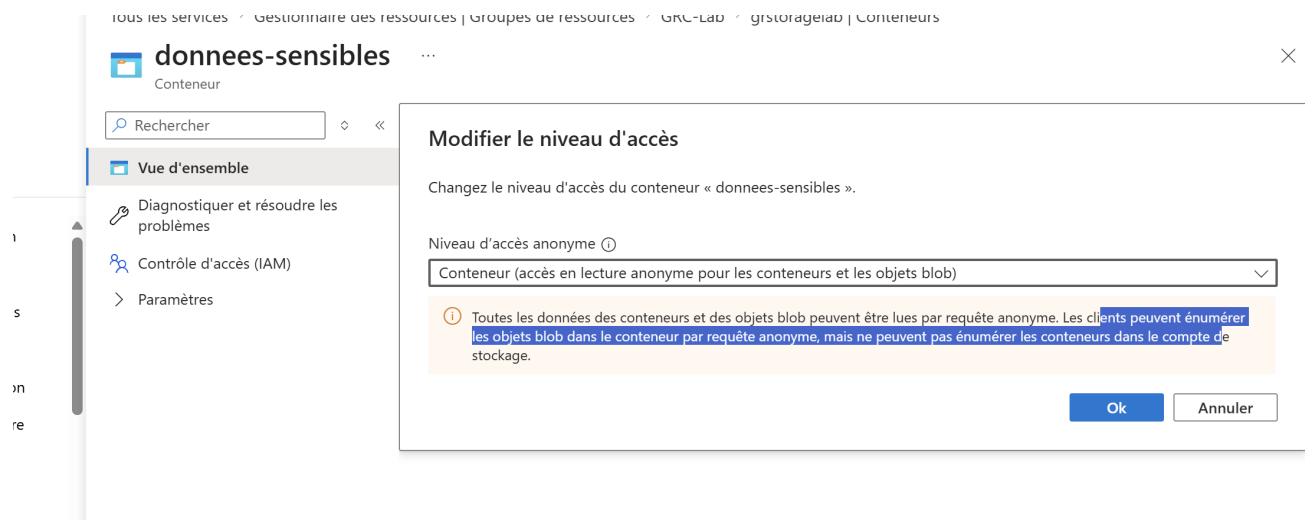


Figure 7 – Configuration plus permissive autorisant la lecture et l'énumération anonymes des objets du conteneur.

Annexe A.7 – Clés d'accès

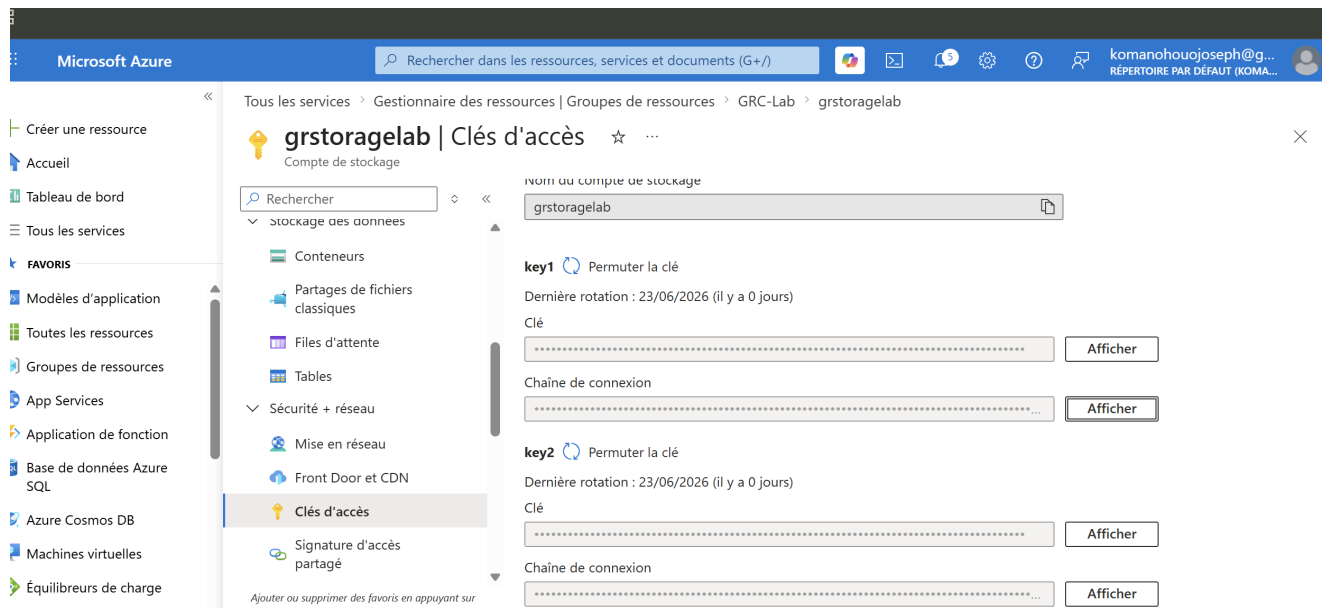


Figure 8 – Présence de deux clés d'accès et de leurs chaînes de connexion associées.

Annexe A.8 – Rappel manuel de rotation

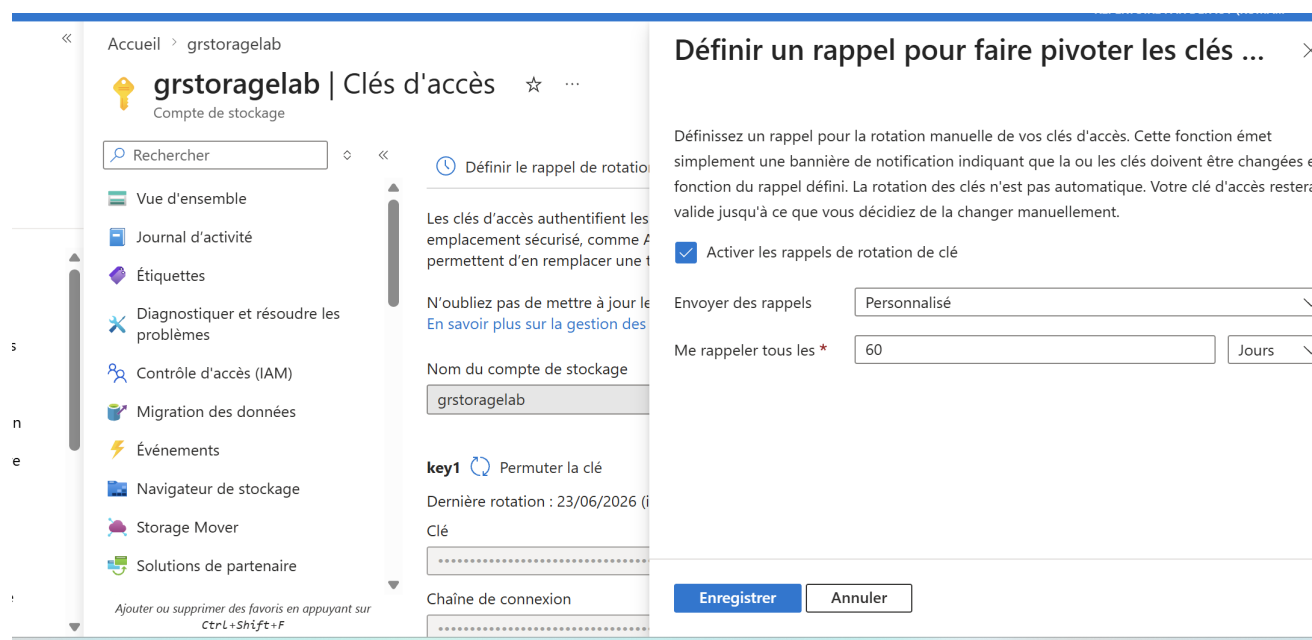


Figure 9 – Configuration d'un rappel manuel de rotation à 60 jours ; ce rappel ne réalise pas la rotation automatiquement.

Annexe A.9 – Vue d’ensemble du compte

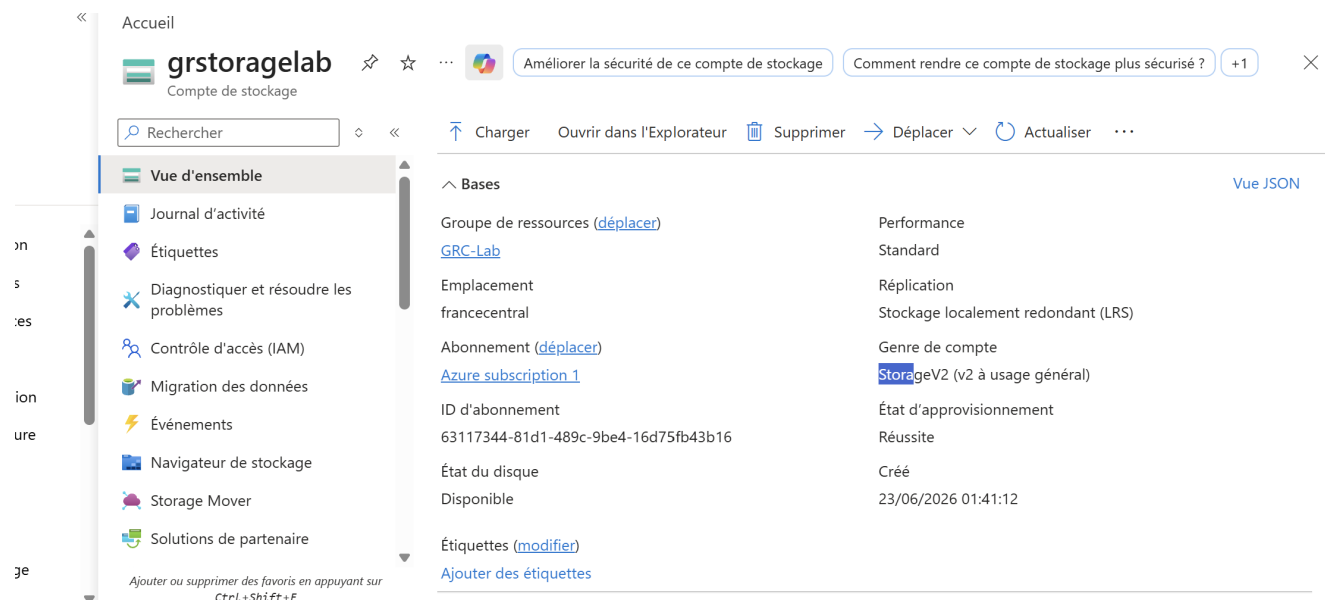


Figure 10 – Vue d’ensemble : région France Central, performance Standard, réplication LRS et type StorageV2.

Annexe A.10 – Accès réseau public

Accueil > grstoragelab | Mise en réseau

Accès au réseau public

Public network access * ⓘ

- ☒ Enable
Allow inbound and outbound access with the option to restrict select inbound access using resource access configurations for this resource.
- ☐ Disable
Restrict inbound access while allowing outbound access.
- ☐ Secured by perimeter (Most restricted)
Restrict inbound and outbound access using a network security perimeter. Secure by perimeter offers the greatest level of inbound and outbound restriction to secure your resource.

⚠ Enabling public network access will make this resource available publicly. Unless public access is required, consider using the most restricted access configurations. [Learn more](#)

Étendue d'accès au réseau public * ⓘ

- ☒ Enable from all networks
- ☐ Enable from selected networks

[Save](#) [Cancel](#)

Figure 11 – Accès réseau public activé depuis tous les réseaux.

Annexe A.11 – Paramètres de diagnostic

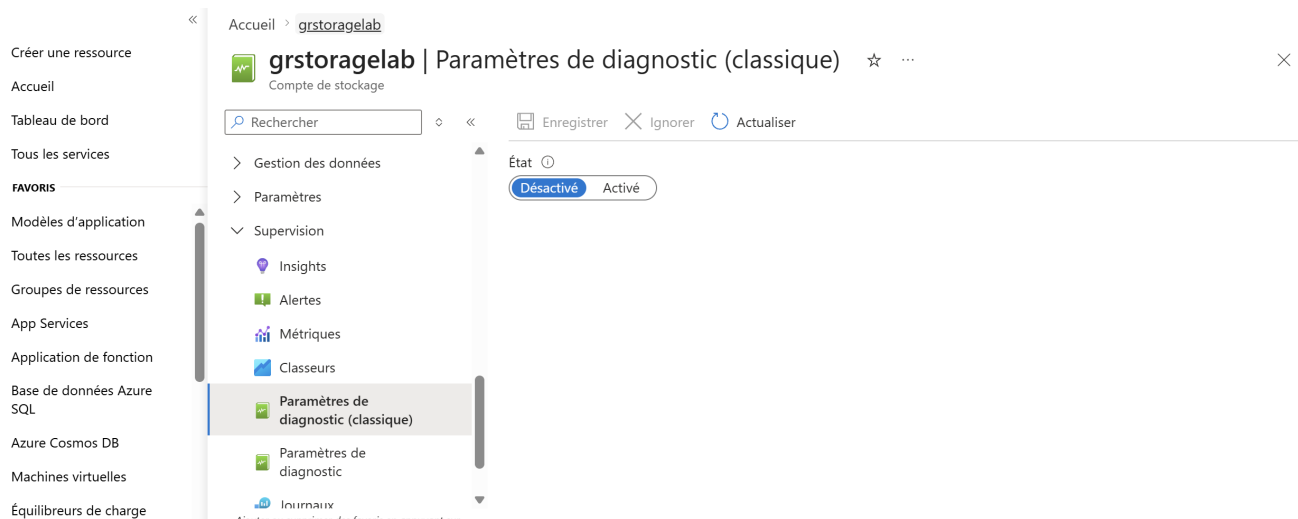


Figure 12 – Paramètres de diagnostic classiques désactivés.

Annexe A.12 – Étendue de l'accès réseau public

Accueil > grstoragelab | Mise en réseau

Accès au réseau public

Public network access * ⓘ

- ☒ Enable
Allow inbound and outbound access with the option to restrict select inbound access using resource access configurations for this resource.
- ☐ Disable
Restrict inbound access while allowing outbound access.
- ☐ Secured by perimeter (Most restricted)
Restrict inbound and outbound access using a network security perimeter. Secure by perimeter offers the greatest level of inbound and outbound restriction to secure your resource.

⚠ Enabling public network access will make this resource available publicly. Unless public access is required, consider using the most restricted access configurations. [Learn more](#)

Étendue d'accès au réseau public * ⓘ

- ☒ Enable from all networks
- ☐ Enable from selected networks

Save Cancel

Figure 13 – *Seconde preuve de l'activation de l'accès public depuis tous les réseaux.*

Annexe A.13 – Rappel de rotation désactivé

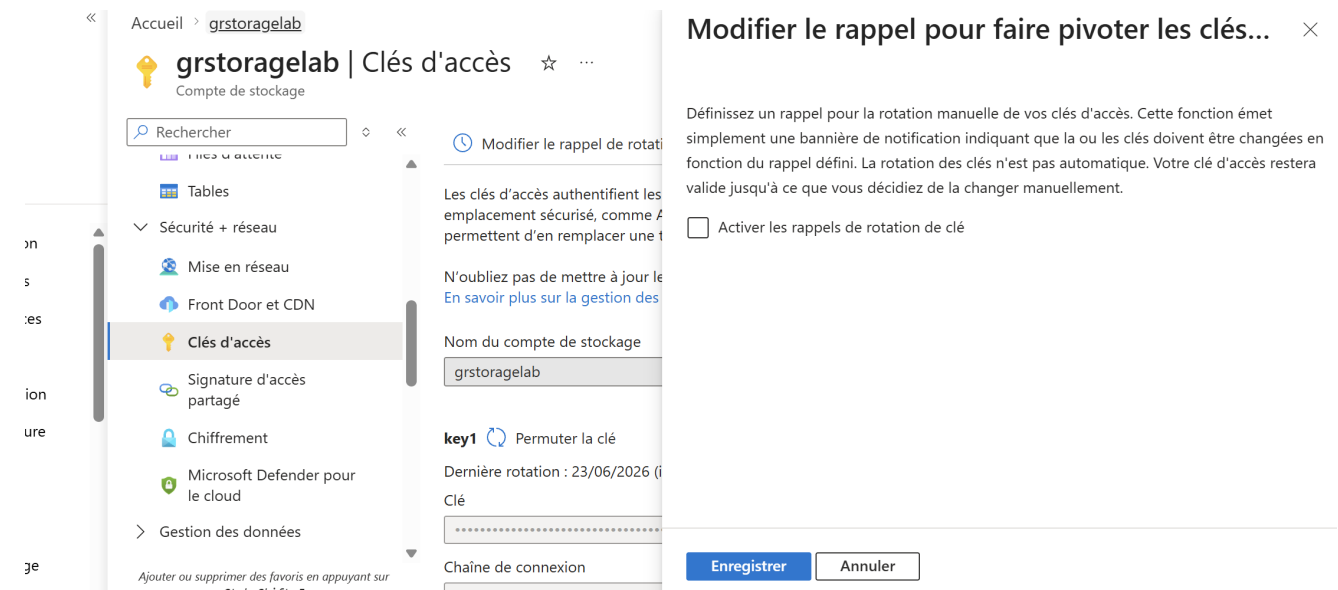


Figure 14 – État observé dans lequel le rappel de rotation des clés est désactivé.